

Best Practices & Example Workflows

Practical guidance for getting the most out of the Security Monitoring Dashboard while keeping yourself, your family, and your targets safe.

1. Securing the dashboard itself

The dashboard is a powerful tool — protect it like a crown-jewel admin panel.

- [] **Change the default password** immediately (`admin / changeme`).
 - [] **Set a strong `secret_key`** in `config.yaml`
(`python3 -c "import secrets; print(secrets.token_hex(32))"`).
 - [] **Never expose port 5000 directly to the internet.** Use one of:
 - nginx reverse proxy + Let's Encrypt TLS, restricted by IP / behind a VPN, or
 - an SSH tunnel: `ssh -L 5000:localhost:5000 user@server` .
 - [] **Restrict who can reach it** with `ufw` :
`sudo ufw allow from <your-ip> to any port 5000` .
 - [] **Run as a dedicated service** (systemd) and review `logs/audit.log` regularly.
 - [] **Keep `data/users.json` mode `600`** (the app enforces this).
-

2. Defensive hardening checklist (the host)

- [] SSH: keys only — `PasswordAuthentication no` , `PermitRootLogin no` .
 - [] `ufw` : default deny inbound, allow only what you need
(`OpenSSH` , app ports).
 - [] `fail2ban` : enabled with the provided `sshd` jail (and web jails if you run web services).
 - [] Keep the system patched: `unattended-upgrades` or regular
`apt-get update && apt-get upgrade` .
 - [] Set `firewall.enforce: true` so dashboard blocks actually apply.
 - [] Configure an alert **webhook** so you hear about high-severity events even when you're not watching.
 - [] Tune `monitoring.connection_threshold` to your normal traffic so the auto-alert fires on genuine anomalies.
-

3. Example workflow — Protecting family computers / a home network

Goal: keep an eye on a home server and notice when something's wrong.

1. Install the dashboard on the always-on home server/Pi
(`sudo ./scripts/setup.sh --all`).
2. Enable `ufw` (default deny inbound) and `fail2ban` .
3. Set `firewall.enforce: true` and a Discord/Slack `webhook_url` .
4. Each morning, check **Overview**:
 - Any **new listening ports**? → investigate (could be unwanted software).
 - **Top talkers** you don't recognize? → block them.
 - **Throughput spikes** overnight? → check what was transferring.
5. If the dashboard alerts on an SSH brute-force or connection flood, the IP is auto-banned (fail2ban) or one click away from blocking.
6. Teach others by walking them through the Overview and Alerts tabs — it's a friendly, visual way to explain "what normal looks like" and how attacks appear.

Tip: access the home dashboard remotely via an SSH tunnel or a VPN (e.g. WireGuard/Tailscale) rather than opening a port.

4. Example workflow — Bug-bounty recon session

Goal: safe, in-scope reconnaissance for a bounty program.

1. Read the program scope. Add in-scope CIDRs to `offensive.target_allowlist` ; add out-of-scope/sensitive hosts to `offensive.target_denylist` . Restart the service.
2. **Scanner → Host Discovery** on the in-scope range → list of live hosts.
3. **Quick Port Scan** the live hosts → fast view of exposed services.
4. **Service & Version Detection** on hosts with open ports → exact versions.
5. **Vulnerability Scan** (NSE `vuln`) on authorized hosts → candidate issues.
6. Pivot to manual testing (Burp/nuclei/etc.) using the enumerated services.
7. Keep the dashboard's scan history + your notes for the report.

Throughout: respect rate limits, stay in scope, and remember the allow-list is your safety net against costly mistakes.

5. Example workflow — Incident response (host compromise suspected)

1. **Connections tab**: filter for unfamiliar remote IPs / processes. Note PIDs.
2. **Block** any malicious remote IPs immediately (enforcing mode).
3. **Overview → Listening Ports**: spot rogue listeners (backdoors).

4. **Alerts / audit log:** reconstruct the timeline (failed logins, scans, blocks).
 5. Snapshot `logs/audit.log` , `logs/alerts.log` , and the blocked-IP list for evidence before remediating.
 6. Remediate (kill processes, rotate creds, patch), then keep monitoring.
-

6. Operational tips

- **DRY-RUN first.** Leave `firewall.enforce: false` while you learn the tool; you'll see exactly which firewall commands would run in `logs/app.log` .
 - **Privileges matter.** Run as root/systemd for full connection visibility, firewall enforcement, OS detection, and fail2ban control.
 - **Log retention.** Forward `logs/*.log` to a central store/SIEM; the alert and audit logs are JSON-lines and easy to ingest.
 - **Backups.** `data/blocked_ips.json` and `data/users.json` hold your state — back them up.
 - **Performance.** Full-port and vuln scans are heavy; use the concurrency cap and schedule them off-peak.
-

7. Ethics reminder

This platform makes it easy to both **defend** and **test**. Use the offensive features **only** with explicit authorization. When in doubt, don't scan. Good security work is as much about responsibility and documentation as it is about tooling.